IMPLEMENTACIÓN DE FIREWALL

PFSENSE

Carles Ochoa

Índice

INSTALACIÓN....3
CONFIGURACIÓN DE LA ZONA LAN Y DMZ....4
CONFIGURACIÓN DE SNAT Y DNAT....6
CREACIÓN DE SERVIDOR VPN CON VPNSERVER....10
CONFIGURACIÓN DEL TÚNEL....14
SURICATA....22
CREACIÓN DE REGLAS....24
IMPLEMENTACIÓN CON SNORT....28

IMPLEMENTACIÓN DE FIREWALL CON PFSENSE

¿Qué es un Firewall?

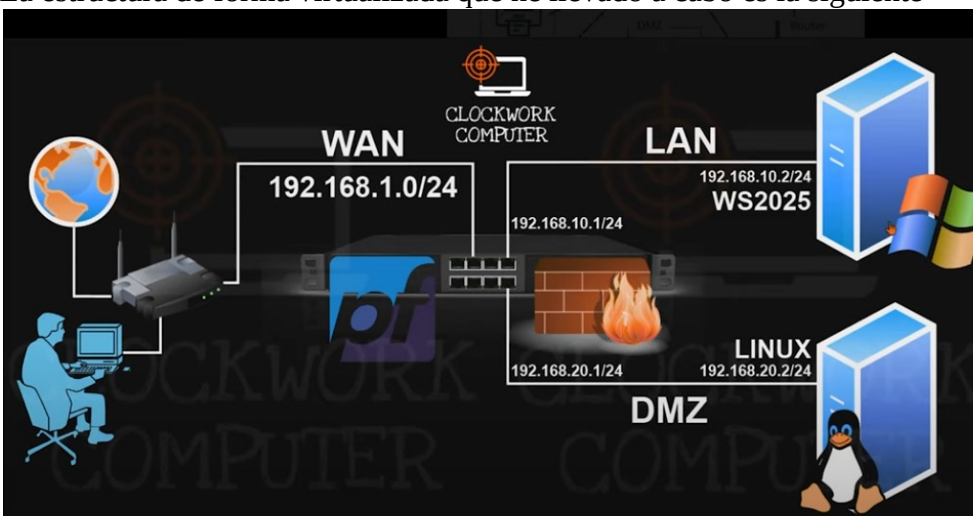
Un firewall es un dispositivo o software de seguridad que monitorea, controla y filtra el trafico de red mediante unas reglas definidas permitiendo o bloqueando conexiones según reglas definidas.

¿Dónde se instala?

Normalmente se coloca entre la red WAN (Internet) y la red LAN (interna). Así todo el tráfico que viene de la red WAN a la LAN pasa por el firewall y viceversa.

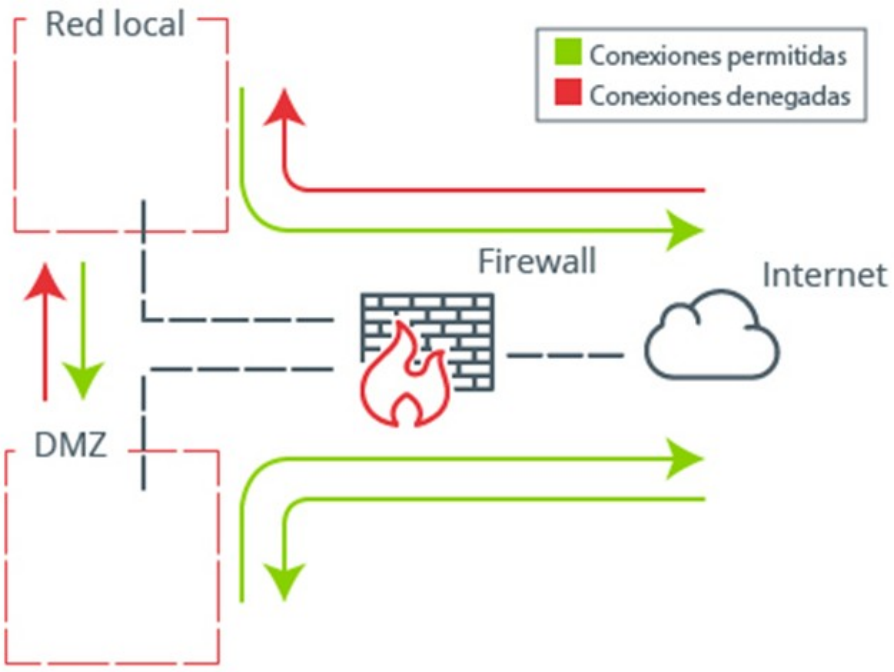
INSTALACIÓN

La estructura de forma virtualizada que he llevado a cabo es la siguiente



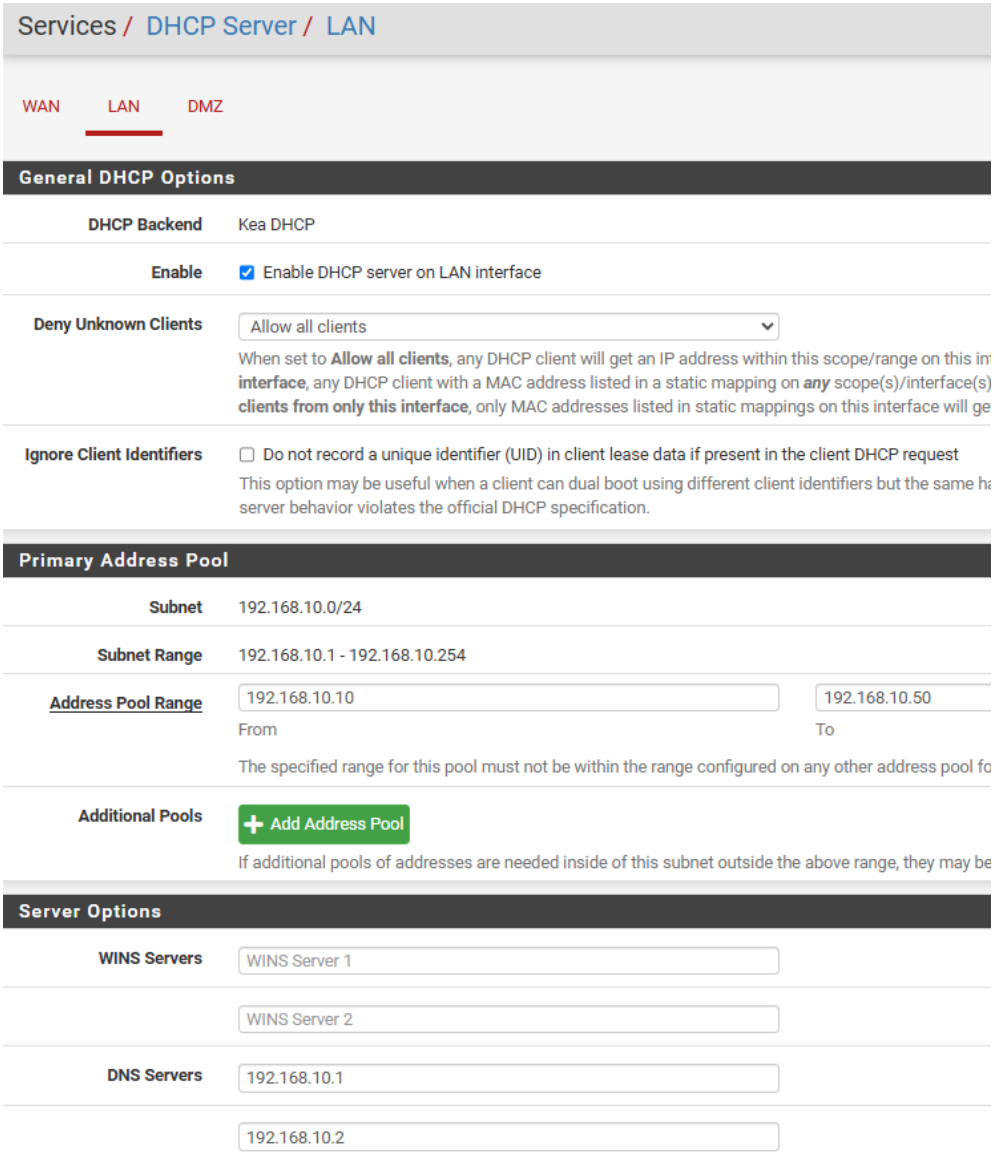
junto con las siguientes reglas

Dirección del tráfico	Resultado	Descripción breve
Internet → Firewall → DMZ	✅ Permitido	Se permite acceso desde Internet a los servicios públicos en la DMZ (con NAT/puertos).
DMZ → Firewall → Internet	✅ Permitido	Los servidores en la DMZ pueden acceder a Internet para actualizaciones, DNS, etc.
Internet → Firewall → Red local (LAN)	❌ Denegado	Se bloquea el acceso directo desde Internet a la red interna por seguridad.
LAN → Firewall → Internet	✅ Permitido	Los usuarios de la red interna pueden navegar por Internet libremente.
LAN → Firewall → DMZ	✅ Permitido	La red interna puede administrar o comunicarse con los servicios de la DMZ.
DMZ → Firewall → LAN	❌ Denegado	Se bloquea el acceso desde la DMZ a la red local para evitar compromisos internos.

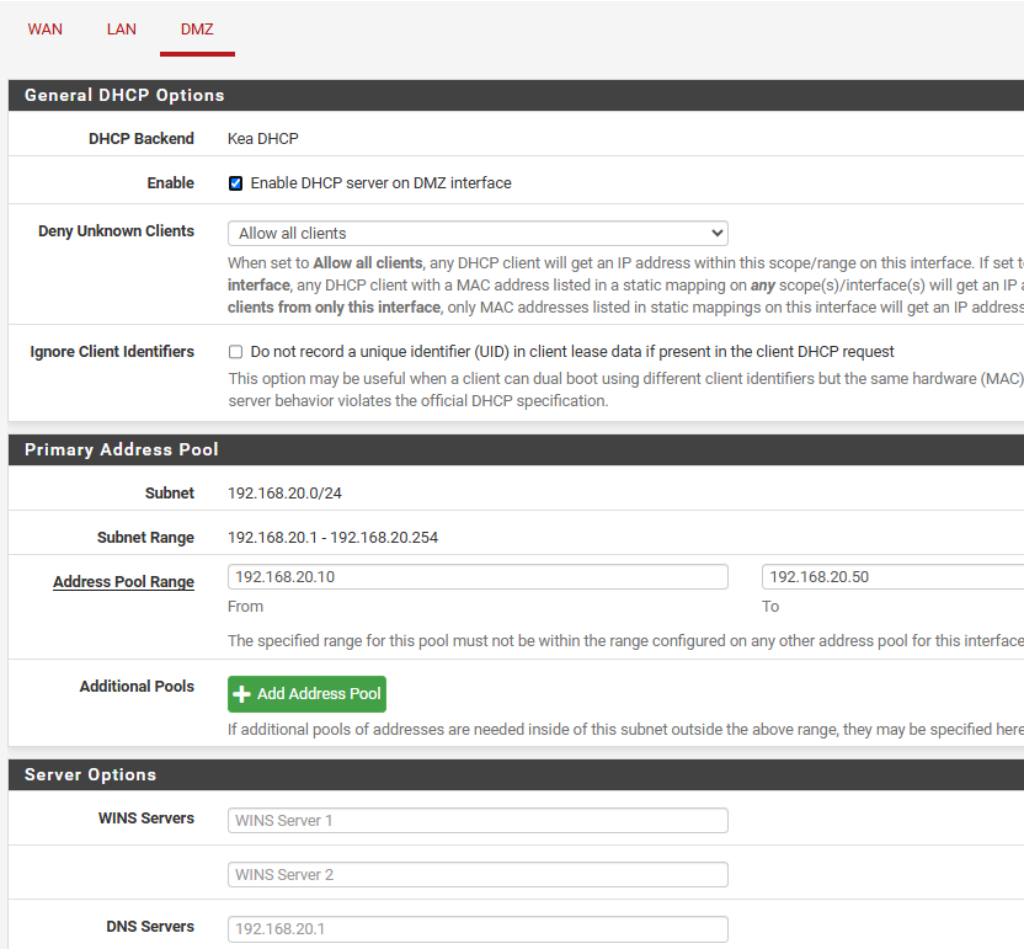


CONFIGURACIÓN DE LA ZONA LAN Y DMZ

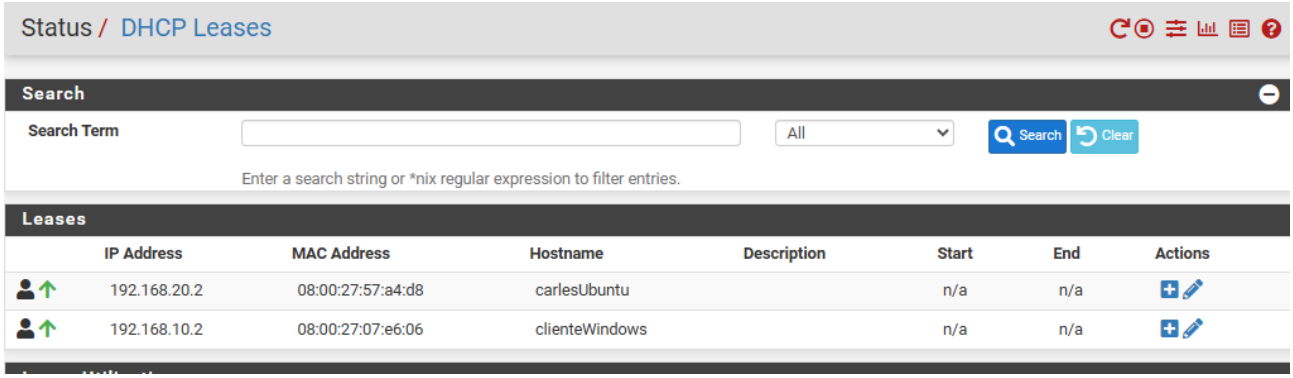
En la red LAN he instalado un Windows 10 que pertenece a la red 192.168.10.0/24 en la que hay instalado un servidor DHCP para que este cliente reciba automáticamente una dirección IP del rango 192.168.10.10 a 192.168.10.50.



Y con la red **DMZ** también. La red DMZ es una red aislada y intermediaria dentro de la misma infraestructura de red que se utiliza para alojar servidores accesibles desde Internet. Esta separación evita que, si un atacante compromete uno de estos servidores, no pueda acceder fácilmente a la LAN interna ya que la LAN es una red y la DMZ otra. En esta red se ha instalado un ubuntu server en la que también recibe una dirección fija a través del DHCP.



Lo siguiente que realicé es asignarles esa dirección ip fija para que siempre reciban esa dirección dada por el DHCP en lugar de otra.



CONFIGURACIÓN DE SNAT Y DNAT

Con toda la infraestructura ya creada, realicé la técnica NAT que lo hace es traducir direcciones IP de origen y destino. Hay dos tipos:

SNAT

Traduce la dirección de origen de un paquete:

- - Se usa cuando una máquina interna (LAN o DMZ) quiere salir a Internet.
- Pfsense cambia la IP privada de origen (por ejemplo, 192.168.20.2) por la IP pública de su interfaz WAN.
- Esto permite que los dispositivos puedan navegar por Internet, aunque tengan IPs privadas.

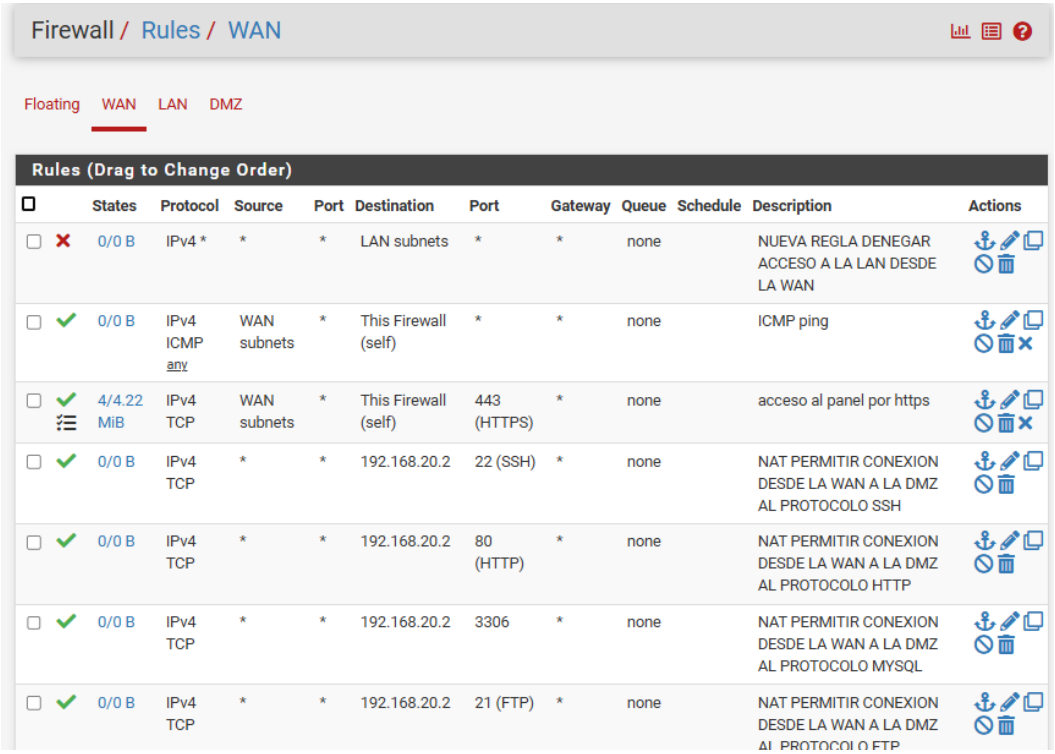
DNAT

Traducción de la dirección de destino de un paquete es decir si alguien quiere acceder a una pagina web que esta alojada en el servidor de la DMZ el proceso que se lleva a cabo es:

- Un usuario envía una solicitud a través de la WAN al puerto 8080 y el DNAT traduce esa dirección redirigiéndola a la dirección del servidor web que esta en la DMZ que en este caso es la 192.168.20.10:8080.

POR LO TANTO LAS REDIRECCIONES SON LAS SIGUIENTES BASÁNDOSE EN LAS DEFINIDAS AL PRINCIPIO DEL FICHERO

INTERFAZ WAN



Firewall / Rules / WAN

Floating WAN LAN DMZ

Rules (Drag to Change Order)

States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
0/0 B	IPv4 *	*	*	LAN subnets	*	*	none		NUEVA REGLA DENEGAR ACCESO A LA LAN DESDE LA WAN	
0/0 B	IPv4 ICMP any	WAN subnets	*	This Firewall (self)	*	*	none		ICMP ping	
4/4.22 MiB	IPv4 TCP	WAN subnets	*	This Firewall (self)	443 (HTTPS)	*	none		acceso al panel por https	
0/0 B	IPv4 TCP	*	*	192.168.20.2	22 (SSH)	*	none		NAT PERMITIR CONEXION DESDE LA WAN A LA DMZ AL PROTOCOLO SSH	
0/0 B	IPv4 TCP	*	*	192.168.20.2	80 (HTTP)	*	none		NAT PERMITIR CONEXION DESDE LA WAN A LA DMZ AL PROTOCOLO HTTP	
0/0 B	IPv4 TCP	*	*	192.168.20.2	3306	*	none		NAT PERMITIR CONEXION DESDE LA WAN A LA DMZ AL PROTOCOLO MYSQL	
0/0 B	IPv4 TCP	*	*	192.168.20.2	21 (FTP)	*	none		NAT PERMITIR CONEXION DESDE LA WAN A LA DMZ AL PROTOCOLO FTP	

La regla que permite acceso al panel desde la WAN NO se debe aplicar en un entorno real ya que cualquier atacante pueda aprovecharse de esta regla y acceder al panel desde Internet. Siempre se debe acceder al panel desde la interfaz LAN. Como esto es un entorno de pruebas virtualizado accedo desde mi propio ordenador que es la WAN pero se debería hacer desde la LAN es decir en la 192.168.10.20.

INTERFAZ LAN

Firewall / Rules / LAN

Floating WAN LAN DMZ

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
	0/0 B	*	*	*	LAN Address	443 80	*	*		Anti-Lockout Rule	
	21/21.32 MiB	IPv4 *	*	*	*	*	*	none		SALIDA A INTERNET (WAN)	
	0/114.07 MiB	IPv4 *	LAN subnets	*	*	*	*	none		Default allow LAN to any rule	
	0/0 B	IPv6 *	LAN subnets	*	*	*	*	none		Default allow LAN IPv6 to any rule	
	0/0 B	IPv4 TCP	*	*	192.168.20.2	445 (MS DS)	*	none		NAT PERMITIR CONEXION DESDE LA LAN A LA DMZ AL PROTOCOLO SMB	
	0/0 B	IPv4 TCP	*	*	192.168.20.2	80 (HTTP)	*	none		NAT PERMITIR CONEXION DESDE LA LAN A LA DMZ AL PROTOCOLO HTTP	

INTERFAZ DMZ

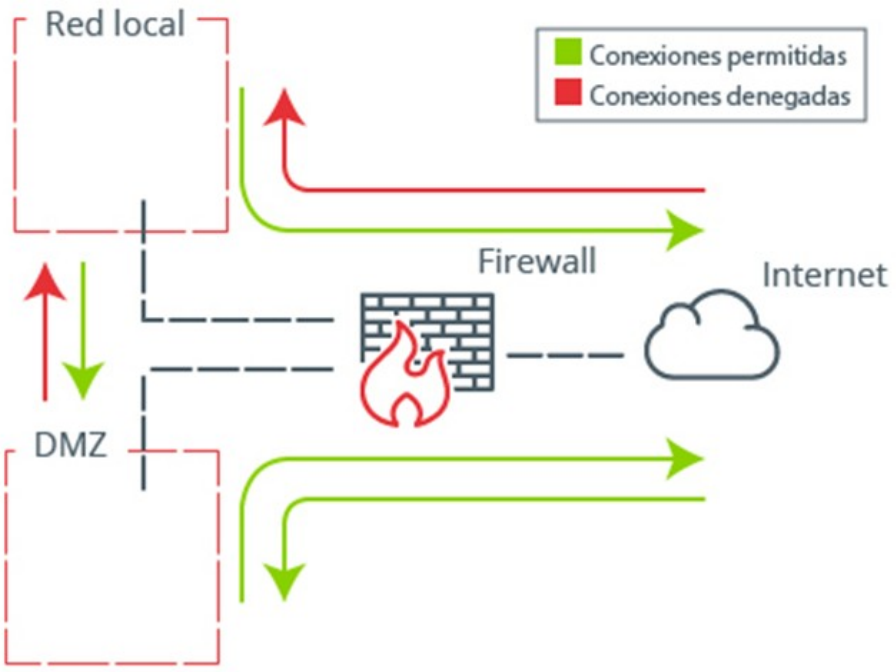
Firewall / Rules / DMZ

Floating WAN LAN DMZ

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
	0/0 B	IPv4 *	*	*	*	*	*	none		SALIDA A INTERNET (WAN)	
	0/0 B	IPv4 *	*	*	LAN subnets	*	*	none		BLOQUEAR DESDE LA DMZ CUALQUIER CONEXIÓN (TCP, UDP, ETC) QUE INTENTE CONECTARSE A UNA DIRECCION DE LA LAN	

Con estas redirecciones lo que se ha diseñado es esta estructura:



LAN:

Tiene acceso a Internet para la navegación y acceso a recursos externos. También puede acceder a la DMZ para consumir servicios públicos (por ejemplo, servidores HTTP, SSH, FTP, etc.).

DMZ:

No tiene acceso a la LAN para evitar que un atacante que comprometa un servidor en la DMZ pueda acceder hacia la red interna.

Sí tiene acceso a Internet, ya que servicios como servidores web, DNS o correo electrónico necesitan comunicarse hacia afuera (actualizaciones, envío de correos, etc.).

WAN (Internet):

No tiene acceso directo a la LAN como medida de seguridad.

Sí tiene acceso a la DMZ, pero solo a los servicios públicos permitidos mediante reglas y NAT (por ejemplo, HTTP, HTTPS, SMTP).

CREACIÓN DE SERVIDOR VPN CON VPNSERVER

¿Qué es OpenVPN Server?

OpenVPN Server es un servicio que permite a usuarios conectarse de forma segura y remota a una red privada (por ejemplo, la red de tu empresa o casa) a través de Internet.

Que es un túnel

Es una conexión segura y cifrada que se establece entre un cliente y un servidor a través de una red pública. Cuando se crea un túnel lo que hay dentro es el cifrado SSL/TSL (como https) certificados digitales (CA) para el servidor como para clientes, la ruta de red a la cual se quiere conectar, reglas de firewall.

IMPLEMENTACIÓN

El primer paso para configurar OpenVPN es generar los certificados necesarios para establecer conexiones seguras. Para ello:

1. Primero se debe crear un Certificado de Autoridad (CA). Este será el responsable de firmar los certificados tanto del servidor como de los clientes.
2. Luego se genera un certificado para el servidor VPN, firmado por la CA que acabamos de crear.
3. Posteriormente, se generarán certificados individuales para cada cliente que necesite conectarse a la VPN. Todos estos certificados estarán firmados también por la misma CA.

Este mecanismo asegura que solo los dispositivos autorizados (es decir, aquellos cuyos certificados están firmados por nuestra CA) puedan establecer conexión con el servidor VPN.

Cuando un cliente intenta conectarse, se produce un intercambio de certificados entre el cliente y el servidor. Si ambos certificados están firmados por la misma CA confiable, la conexión será aceptada. En caso contrario, la conexión será rechazada.

System / Certificate / Authorities / Edit

Authorities | Certificates | Revocation

Create / Edit CA

Descriptive name	CA_OPENVPN The name of this entry as displayed in the GUI for reference. This name can contain spaces but it cannot contain any of the following characters: ?, >, <, &, /, \, ", '
Method	Create an internal Certificate Authority
Trust Store	☐ Add this Certificate Authority to the Operating System Trust Store When enabled, the contents of the CA will be added to the trust store so that they will be trusted by the operating system.
Randomize Serial	☐ Use random serial numbers when signing certificates When enabled, if this CA is capable of signing certificates then serial numbers for certificates signed by this CA will be automatically randomized and checked for uniqueness instead of using the sequential value from Next Certificate Serial.

Internal Certificate Authority

Key type	RSA
	2048 The length to use when generating a new RSA key, in bits. The Key Length should not be lower than 2048 or some platforms may consider the certificate invalid.
Digest Algorithm	sha256 The digest method used when the CA is signed. The best practice is to use SHA256 or higher. Some services and platforms, such as the GUI web server and OpenVPN, consider weaker digest algorithms invalid.
Lifetime (days)	3650
Common Name	CA_OPENVPN
	The following certificate authority subject components are optional and may be left blank.
Country Code	ES
State or Province	ES
City	ES
Organization	carles.lan
Organizational Unit	carles.lan

System / Certificates / Certificates / Edit

Authorities | Certificates | Certificate Revocation

Add/Sign a New Certificate

Method	Create an internal Certificate
Descriptive name	CERT_OPENVPN The name of this entry as displayed in the GUI for reference. This name can contain spaces but it cannot contain any of the following characters: ?, >, <, &, /, \, ", '

Internal Certificate

Certificate authority	CA_OPENVPN
Key type	RSA
	2048 The length to use when generating a new RSA key, in bits. The Key Length should not be lower than 2048 or some platforms may consider the certificate invalid.
Digest Algorithm	sha256 The digest method used when the certificate is signed. The best practice is to use SHA256 or higher. Some services and platforms, such as the GUI web server and OpenVPN, co algorithms invalid.
Lifetime (days)	365 The length of time the signed certificate will be valid, in days. Server certificates should not have a lifetime over 398 days or some platforms may consider the certificate invalid.
Common Name	CERT_OPENVPN
	The following certificate subject components are optional and may be left blank.
Country Code	ES
State or Province	ES
City	ES
Organization	carles.lan
Organizational Unit	carles.lan

Authorities | Certificates | Revocation

Search

Search term | Both | Search | Clear

Enter a search string or *nix regular expression to search certificate names and distinguished names.

Certificate Authorities

Name	Internal	Issuer	Certificates	Distinguished Name	In Use	Actions
CA_Proxy	✔	*self-signed*	1	ST=ES, OU=EmpresaCarles, O=ES, L=ES, CN=carles.lan, C=ES Valid From: **Tue, 06 May 2025 10:28:14 +0000** Valid Until: **Fri, 04 May 2035 10:28:14 +0000**		
CA_Proxy_Firma	✔	*CA_Proxy*	0	ST=ES, OU=EmpresaCarles, O=ES, L=ES, CN=carles.lan, C=ES Valid From: **Tue, 06 May 2025 10:30:57 +0000** Valid Until: **Fri, 04 May 2035 10:30:57 +0000**	Squid (1)	
CA_OPENVPN	✔	*self-signed*	0	ST=ES, OU=carles.lan, O=carles.lan, L=ES, CN=CA_OPENVPN, C=ES Valid From: **Wed, 07 May 2025 07:27:51 +0000** Valid Until: **Sat, 05 May 2035 07:27:51 +0000**		

+ Add

El siguiente paso fue crear el servidor OpenVPN desde VPN»OpenVPN. Asignando como modo de configuración ek ssl/tsl + User Auth ya que podrán acceder los usuarios de pfsense y como interfaz será la WAN ya que lo que se quiere es acceder desde la WAN a la LAN.

VPN / OpenVPN / Servers / Edit

Servers | Clients | Client Specific Overrides | Wizards

General Information

Description	OPENVPN A description of this VPN for administrative reference.
Disabled	☐ Disable this server Set this option to disable this server without removing it from the list.

Mode Configuration

Server mode	Remote Access (SSL/TLS + User Auth)
Backend for authentication	Local Database
Device mode	tun - Layer 3 Tunnel Mode "tun" mode carries IPv4 and IPv6 (OSI layer 3) and is the most common and compatible mode across all platforr "tap" mode is capable of carrying 802.3 (OSI Layer 2.)

Endpoint Configuration

Protocol	UDP on IPv4 only
Interface	WAN The interface or Virtual IP address where OpenVPN will receive client connections.
Local port	1194 The port used by OpenVPN to receive client connections.

Advanced Client Settings

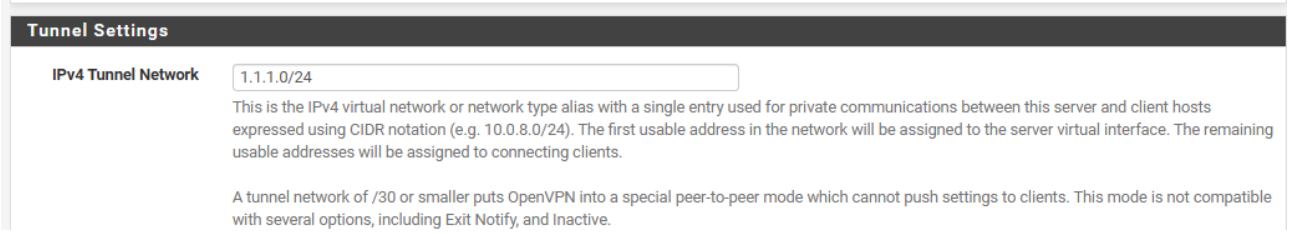
DNS Default Domain	☑ Provide a default domain name to clients
DNS Default Domain	carles.lan
DNS Server enable	☑ Provide a DNS server list to clients. Addresses may be IPv4 or IPv6.
DNS Server 1	192.168.10.1
DNS Server 2	192.168.10.2
DNS Server 3	
DNS Server 4	
Block Outside DNS	☐ Make Windows 10 Clients Block access to DNS servers except across OpenVPN while connected, forcing clients to use only VPN DNS servers. Requires Windows 10 and OpenVPN 2.3.9 or later. Only Windows 10 is prone to DNS leakage in this way, other clients will ignore the option as they ar not affected.
Force DNS cache update	☑ Run "net stop dnscache", "net start dnscache", "ipconfig /flushdns" and "ipconfig /registerdns" on connection initiation. This is known to kick Windows into recognizing pushed DNS servers.
NTP Server enable	☐ Provide an NTP server list to clients
NetBIOS enable	☐ Enable NetBIOS over TCP/IP If this option is not set, all NetBIOS-over-TCP/IP options (including WINS) will be disabled.

Cryptographic Settings

TLS Configuration	☑ Use a TLS Key A TLS key enhances security of an OpenVPN connection by requiring both parties to have a common key before a peer can perform a TLS handshake. This layer of HMAC authentication allows control channel packets without the proper key to be dropped, protecting the peers from attack or unauthorized connections.The TLS Key does not have any effect on tunnel data.
	☑ Automatically generate a TLS Key.
Peer Certificate Authority	CA_OPENVPN
Peer Certificate Revocation list	No Certificate Revocation Lists defined. One may be created here: System > Cert. Manager
OCSP Check	☐ Check client certificates with OCSP
Server certificate	CERT_OPENVPN (Server: Yes, CA: CA_OPENVPN) Certificates known to be incompatible with use for OpenVPN are not included in this list, such as certificates using incompatible ECDSA curves or weak digest algorithms.
DH Parameter Length	2048 bit Diffie-Hellman (DH) parameter set used for key exchange.
ECDH Curve	Use Default The Elliptic Curve to use for key exchange. The curve from the server certificate is used by default when the server uses an ECDSA certificate. Otherwise, secp384r1 is used as a fallback.
Data Encryption Algorithms	AES-128-CBC (128 bit key, 128 bit block) AES-128-CFB (128 bit key, 128 bit block) AES-128-CFB1 (128 bit key, 128 bit block) AES-128-CFB8 (128 bit key, 128 bit block) AES-128-GCM (128 bit key, 128 bit block) AES-128-OFB (128 bit key, 128 bit block) AES-192-CBC (192 bit key, 128 bit block) AES-192-CFB (192 bit key, 128 bit block) AES-192-CFB1 (192 bit key, 128 bit block) AES-192-CFB8 (192 bit key, 128 bit block) Available Data Encryption Algorithms Click to add or remove an algorithm from the list AES-256-GCM AES-128-GCM CHACHA20-POLY1305 Allowed Data Encryption Algorithms. Click an algorithm name to remove it from the list The order of the selected Data Encryption Algorithms is respected by OpenVPN. This list is ignored in Shared Key mode.
Fallback Data Encryption Algorithm	AES-256-CBC (256 bit key, 128 bit block) The Fallback Data Encryption Algorithm used for data channel packets when communicating with clients that do not support data encryption algorithm negotiation (e.g. Shared Key). This algorithm is automatically included in the Data Encryption Algorithms list.
Auth digest algorithm	SHA256 (256-bit) The algorithm used to authenticate data channel packets, and control channel packets if a TLS Key is present. When an AEAD Encryption Algorithm mode is used, such as AES-GCM, this digest is used for the control channel only, not the data channel. The server and all clients must have the same setting. While SHA1 is the default for OpenVPN, this algorithm is insecure.
Hardware Crypto	No Hardware Crypto Acceleration
Certificate Depth	One (Client+Server) When a certificate-based client logs in, do not accept certificates below this depth. Useful for denying certificates made with intermediate CAs generated from the same CA as the server.
Strict User-CN Matching	☐ Enforce match When authenticating users, enforce a match between the common name of the client certificate and the username given at login.
Client Certificate Key Usage Validation	☑ Enforce key usage Verify that only hosts with a client certificate can connect (EKU: "TLS Web Client Authentication").

CONFIGURACIÓN DEL TÚNEL

El primer paso es asignar una dirección de red cualquiera que lo que va a hacer es que cuando el equipo anfitrión se conecte al túnel pfsense otorgará una dirección IP dentro de la red asignada.



El siguiente parámetro a configurar es **"IPv4 Local Network".**

Este campo se utiliza para indicar qué red local (LAN) estará disponible una vez se establezca el túnel VPN. Es decir, define la red interna a la que los clientes remotos podrán acceder cuando se conecten a través del túnel (por ejemplo, 192.168.1.0/24).

Esto le dice al servidor VPN qué red debe anunciar a los clientes para que puedan comunicarse con los equipos dentro de esa LAN.

Redirect IPv4 Gateway	☐ Force all client-generated IPv4 traffic through the tunnel.
Redirect IPv6 Gateway	☐ Force all client-generated IPv6 traffic through the tunnel.
IPv4 Local network(s)	192.168.10.0/24 IPv4 networks that will be accessible from the remote endpoint. Expressed as a comma-separated l type aliases. This may be left blank if not adding a route to the local network through this tunnel on t LAN network.
IPv6 Local network(s)	IPv6 networks that will be accessible from the remote endpoint. Expressed as a comma-separated l aliases. This may be left blank if not adding a route to the local network through this tunnel on the re network.
Concurrent connections	Specify the maximum number of clients allowed to concurrently connect to this server.
Allow Compression	Refuse any non-stub compression (Most secure) Allow compression to be used with this VPN instance. Compression can potentially increase throughput but may allow an attacker to extract secrets if they VPN (e.g. HTTP). Before enabling compression, consult information about the VORACLE, CRIME, TIM the use case for this specific VPN is vulnerable to attack. Asymmetric compression allows an easier transition when connecting with older peers.
Push Compression	☐ Push the selected Compression setting to connecting clients.
Type-of-Service	☐ Set the TOS IP header value of tunnel packets to match the encapsulated packet value.
Inter-client communication	☐ Allow communication between clients connected to this server
Duplicate Connection	☐ Allow multiple concurrent connections from the same user When set, the same user may connect multiple times. When unset, a new connection from a user wi Users are identified by their username or certificate properties, depending on the VPN configuration. may be necessary in some environments.

El siguiente paso a realizar fue crear **una regla en el firewall de pfSense.**

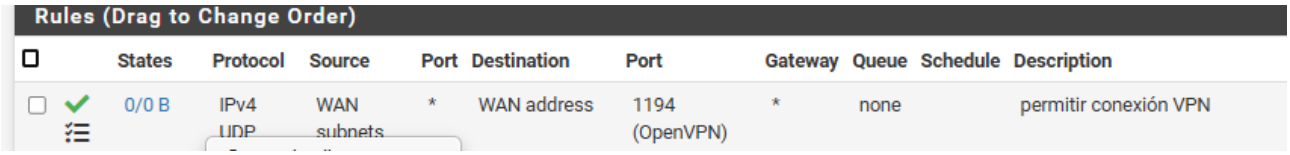
Esta regla permitirá que los clientes externos (desde Internet) puedan iniciar una conexión VPN hacia nuestro servidor OpenVPN.

Lo que hace esta regla es:

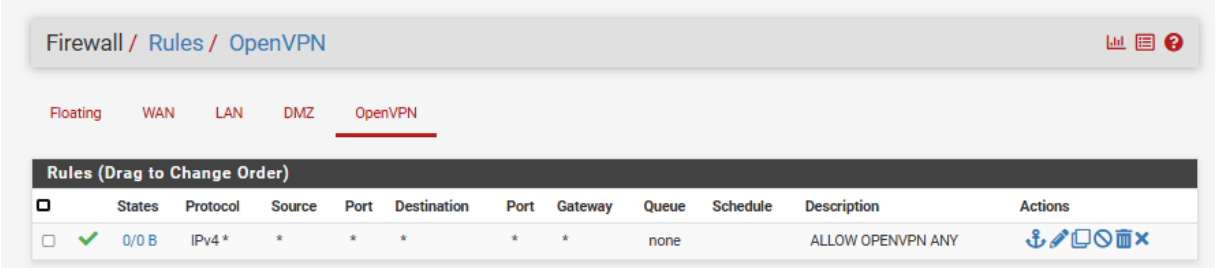
- **Interfaz:** WAN (porque los clientes se conectarán desde fuera de la red local).
- **Protocolo:** UDP (porque OpenVPN usa este protocolo por defecto).
- **Puerto de destino:** 1194 (es el puerto estándar para OpenVPN).
- **Dirección IP de origen:** WAN o cualquier (any), para aceptar conexiones desde cualquier IP externa.

- **Acción:** permitir (pass).

Esta regla autoriza el tráfico entrante por el puerto 1194/UDP, que luego será manejado por el servidor OpenVPN configurado en pfSense.



Otra regla a crear es la de OpenVPN que sirve para permitir todo el tráfico que venga a través del túnel VPN, una vez que un cliente ya se ha conectado correctamente al servidor VPN.



El siguiente paso fue crear el usuario para conectarnos a openvpn, que estos usuarios son los locales de pfsense.

System / User Manager / Users / Edit

Users | Groups | Settings | Authentication Servers

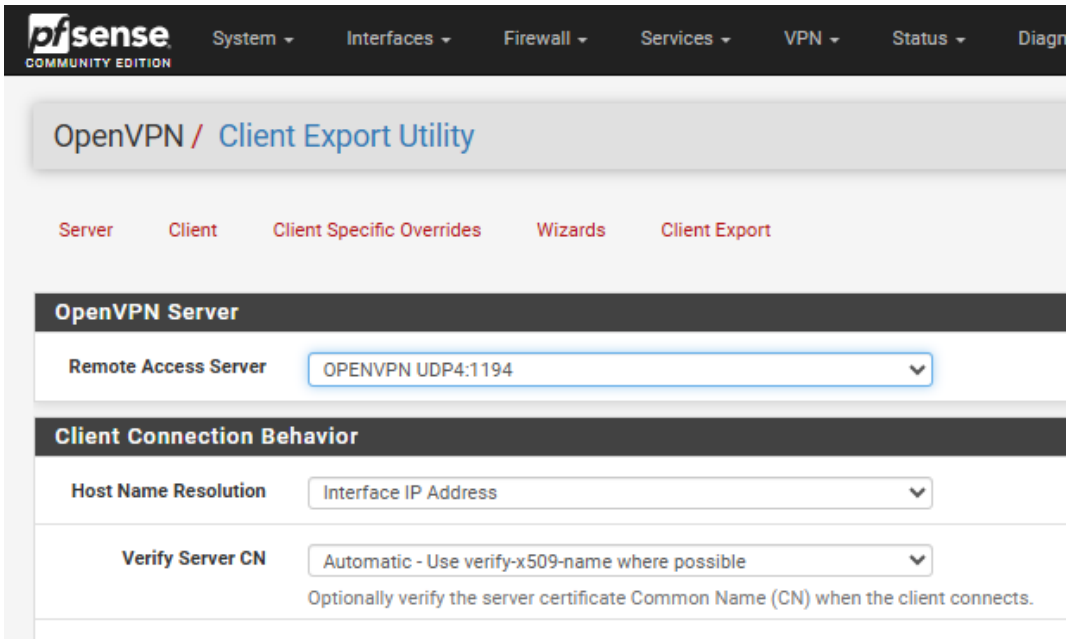
User Properties

Defined by	USER
Disabled	☐ This user cannot login
Username	pedro
Password	••••••••• •••••••••
Full name	pedro User's full name, for administrative information only
Expiration date	Leave blank if the account shouldn't expire, otherwise enter the expiration date as MM/DD/YYYY
Custom Settings	☐ Use individual customized GUI options and dashboard layout for this user.
Group membership	admins Not member of Member of
	Move to "Member of" list / Move to "Not member of" list Hold down CTRL (PC)/COMMAND (Mac) key to select multiple items.
Certificate	☑ Click to create a user certificate

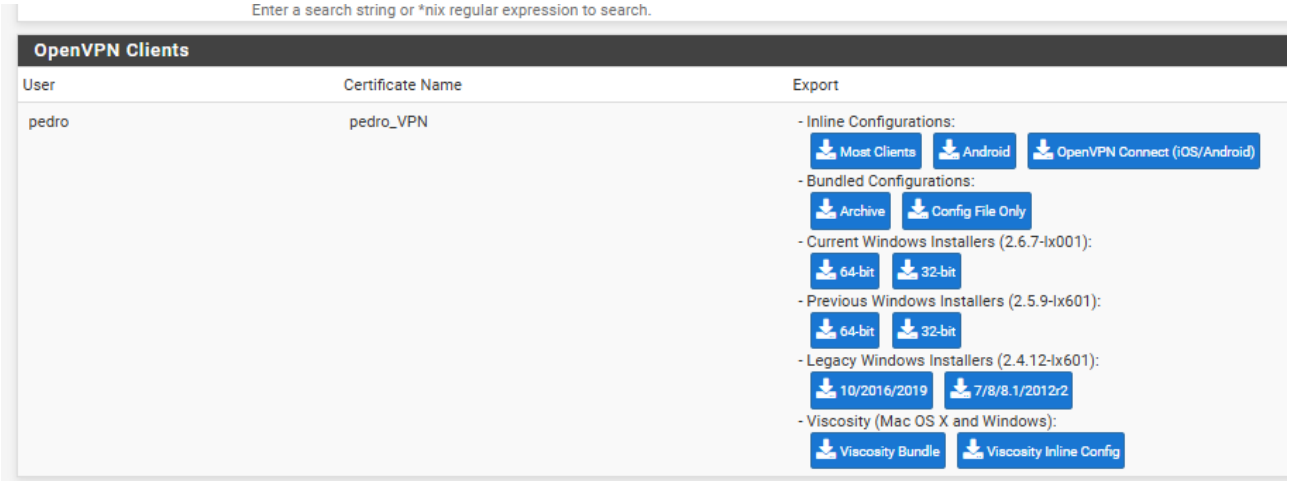
Create Certificate for User

Descriptive name	pedro_VPN
Certificate authority	CA_OPENVPN
Key type	RSA
	2048 The length to use when generating a new RSA key, in bits. The Key Length should not be lower than 2048 or some platforms may consider the certificate invalid.
Digest Algorithm	sha256 The digest method used when the certificate is signed. The best practice is to use an algorithm stronger than SHA1. Some platforms may consider weaker digest algorithms invalid
Lifetime	3650

Con el usuario ya creado tan solo faltará exportar la configuración del usuario para probarlo en un equipo.

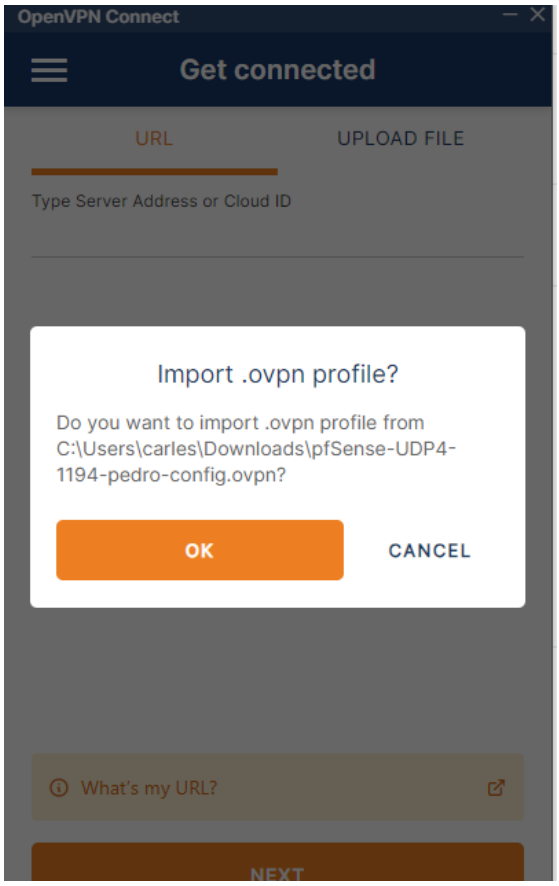


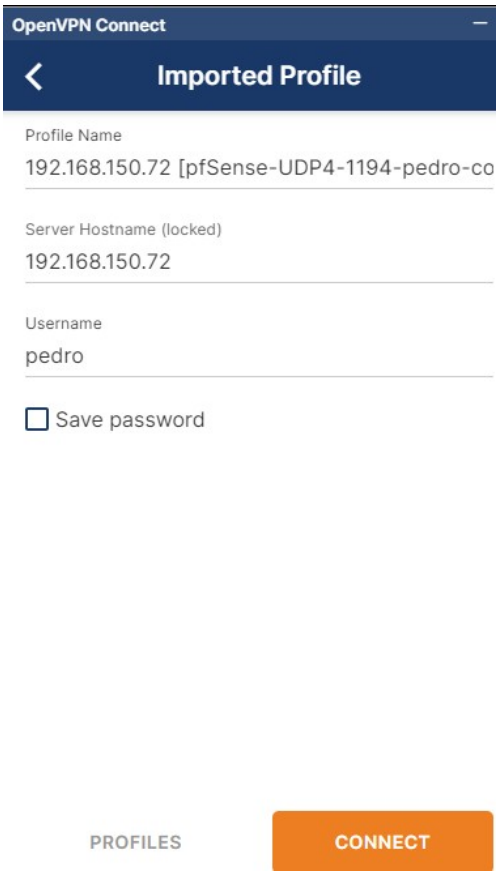
Utilizando la de most clients



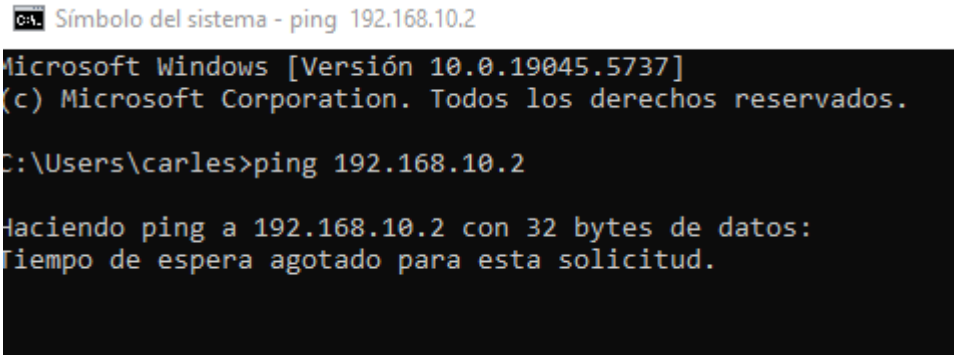
En el equipo cliente se debe descargar el cliente de openvpn para poder establecer la conexión.

Una vez descargado se pulsará sobre el archivo descargado para importar la configuración.

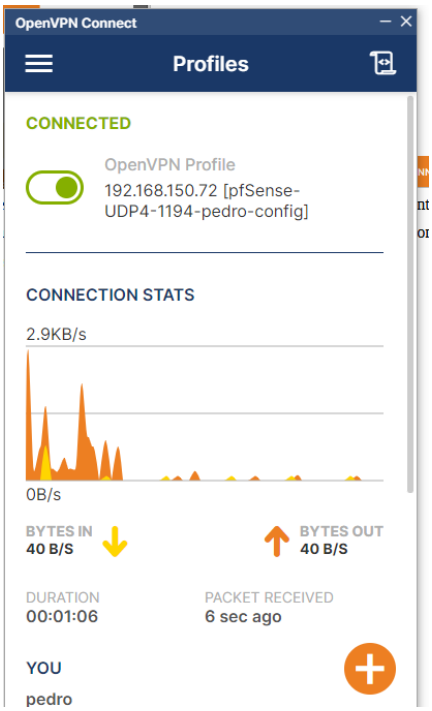




El server hostname es la dirección WAN que en este caso es mi adaptador puente pero en un caso real esto seria una IP pública. Vemos que al hacer ping no tenemos respuesta.

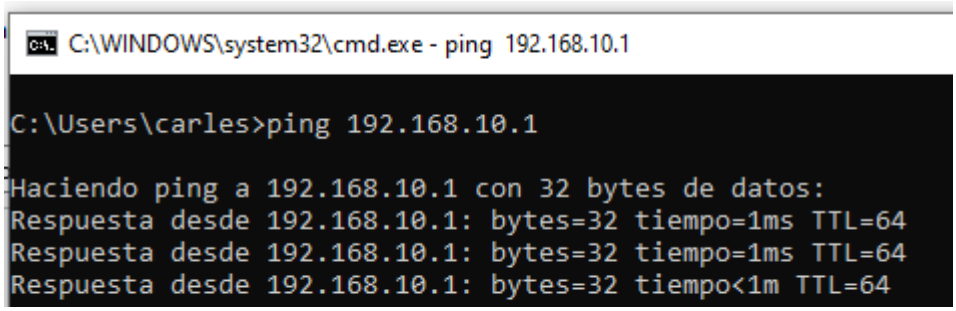


Pero al pulsar sobre conectar habrá que introducir la contraseña y ya estaremos conectados



Con esta configuración se ha creado un túnel hacia la LAN

Ahora si hacemos ping desde la 192.168.150.0 a la 192.168.10.1 funcionará.



Por último realizaremos una conexión de escritorio remoto ya que principalmente una VPN se crea con este objetivo pero para ello en el equipo que se desea realizar la conexión remota se debe ejecutar el siguiente script.

Habilitar RDP

Set-ItemProperty -Path "HKLM:\System\CurrentControlSet\Control\Terminal Server" -Name "fDenyTSConnections" -Value 0

Permitir RDP en el firewall (TCP y UDP)

Enable-NetFirewallRule -Name "RemoteDesktop-UserMode-In-TCP"

Enable-NetFirewallRule -Name "RemoteDesktop-UserMode-In-UDP"

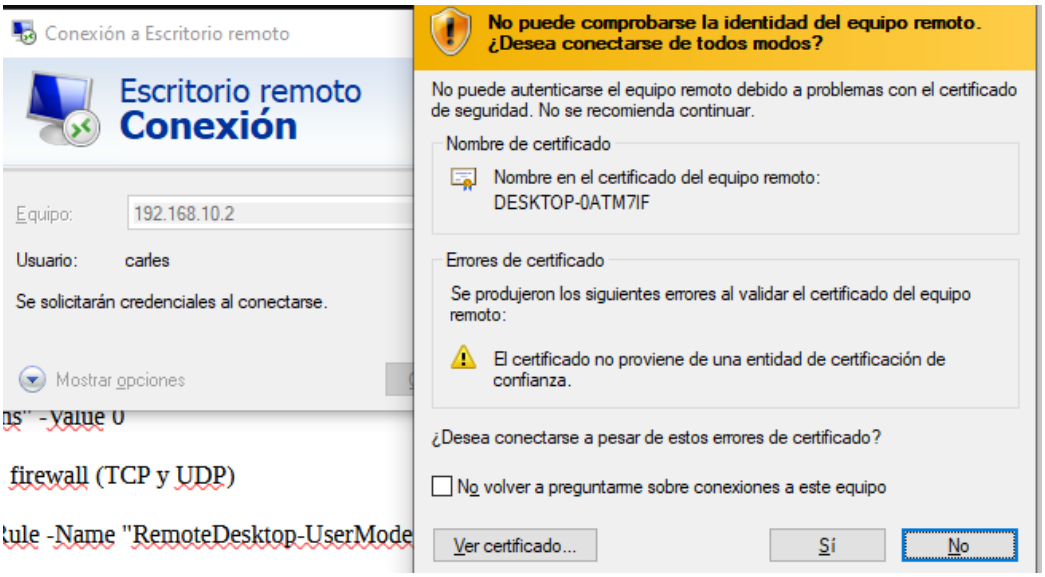
Permitir ping (ICMP Echo)

Enable-NetFirewallRule -Name "FPS-ICMP4-ERQ-In"

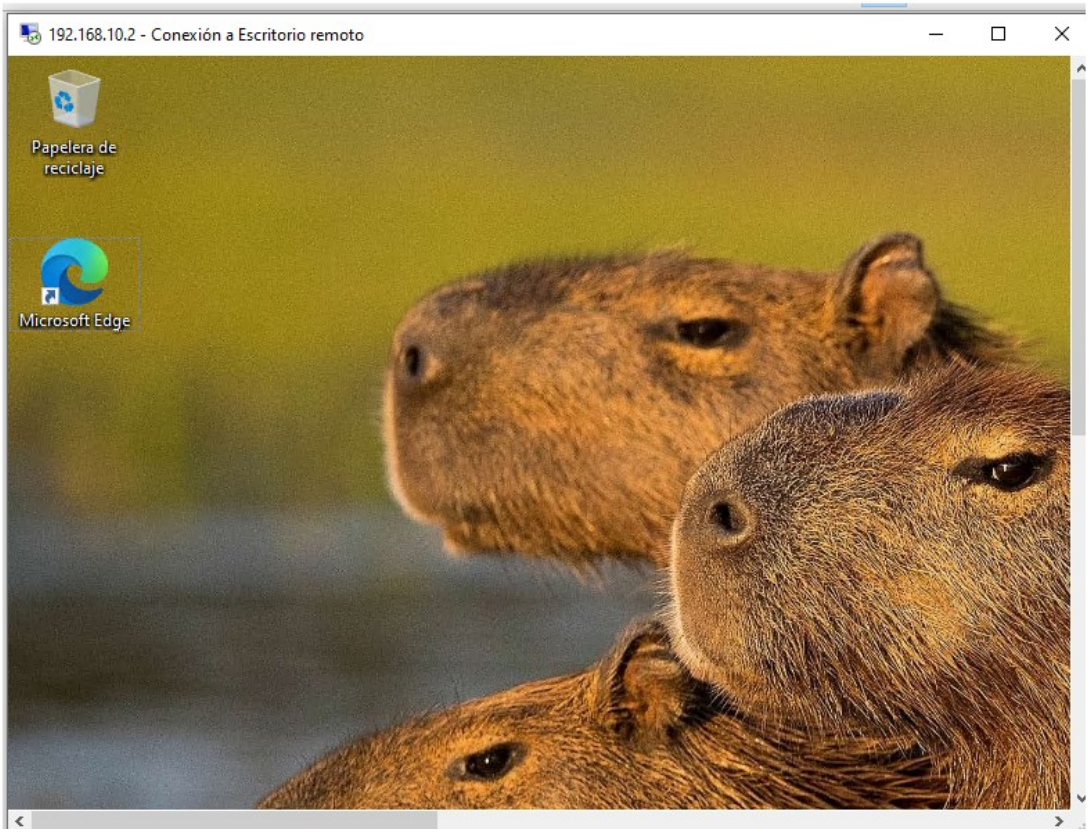
Cambiar red actual a "Privada"

Get-NetConnectionProfile | Set-NetConnectionProfile -NetworkCategory Private

Y realizamos la conexión al cliente



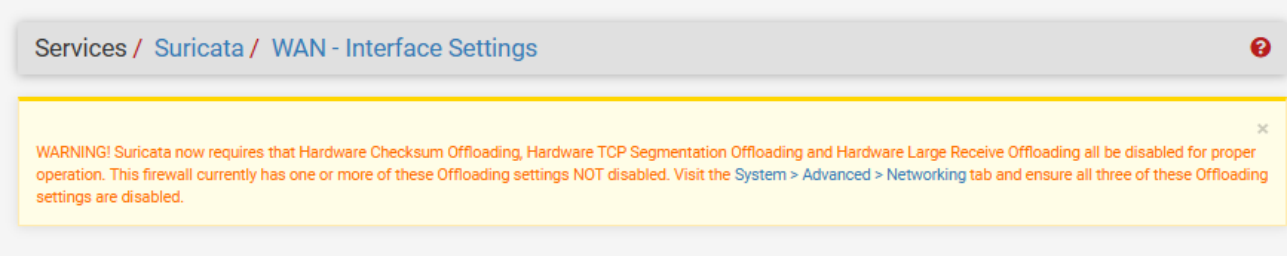
Y estaremos conectados remotamente desde la red 192.168.150.0

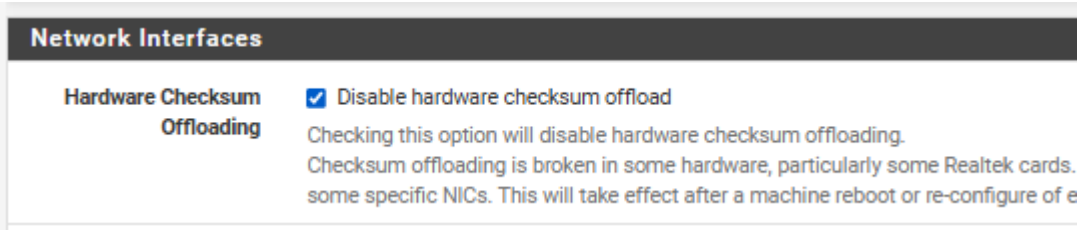


SURICATA

Suricata es una herramienta de seguridad que actúa como detector de IDS detector de intrusos mediante reglas. Es decir va analizar el tráfico de red sin intervenir en el, lo que hará es detectar actividades sospechosas basadas en las reglas que vamos a implementar y generará logs y registros.

Para ello primero se debe instalar el paquete de suricata. Y aplicar las siguientes configuraciones





Logging Settings

Send Alerts to System Log	☐ Suricata will send Alerts from this interface to the firewall's system log. NOTE: the FreeBSD syslog daemon will automatically truncate exported messages to 480 bytes max.
Enable Stats Collection	☐ Suricata will periodically gather performance statistics for this interface. Default is Not Checked.
Enable HTTP Log	☑ Suricata will log decoded HTTP traffic for the interface. Default is Checked.
HTTP Log File Type	Regular Select "Regular" to log to a conventional file, or choose UNIX "Datagram" or "Stream" Socket to log to an existing UNIX socket. Default is "Regular"
Append HTTP Log	☑ Suricata will append-to instead of clearing HTTP log file when restarting. Default is Checked.
Log Extended HTTP Info	☑ Suricata will log extended HTTP information. Default is Checked.
Enable TLS Log	☐ Suricata will log TLS handshake traffic for the interface. Default is Not Checked.
Enable File-Store	☐ Suricata will extract and store files from application layer streams. Default is Not Checked. WARNING: Enabling file-store will consume a significant amount of disk space on a busy network!
Enable Packet Log	☐ Suricata will log decoded packets for the interface in pcap-format. Default is Not Checked. This can consume a significant amount of disk space when enabled. Use the Packet Log Conditional setting below to select packets for capture.
Enable Verbose Logging	☐ Suricata will log additional information to the suricata.log file when starting up and shutting down. Default is Not Checked.

EVE Output Settings

EVE JSON Log	☐ Suricata will output selected info in JSON format to a single file or to syslog. Default is Not Checked.

Alert and Block Settings

Block Offenders	☐ Checking this option will automatically block hosts that generate a Suricata alert.

Performance and Detection Engine Settings

Run Mode	AutoFP Choose a Suricata run mode setting. Default is "AutoFP" and is the recommended setting for IDS-only and Legacy Blocking Mode. "Workers" uses multiple worker threads, each of which processes the packets it acquires through all the decode and detect modules. "Workers" runmode is preferred for Inline IPS Mode blocking because it offers superior performance in that configuration. "Single" uses only a single thread for all operations, and is intended for use only in testing or development instances.
AutoFP Scheduler Type	Hash Choose the kind of flow load balancer used by the flow pinned autofp mode. "Hash" assigns the flow to a thread using the 5-7 tuple hash. "IP Pair" assigns the flow to a thread using addresses only. This setting is applicable only when the Run Mode is set to "autofp".
Max Pending Packets	1024 Enter number of simultaneous packets to process. Default is 1024. This controls the number of simultaneous packets the engine can handle. Setting this higher generally keeps the threads more busy. The minimum value is 1 and the maximum value is 65,000. Warning: Setting this too high can lead to degradation and a possible system crash by exhausting available memory.
Detect-Engine Profile	Medium Choose a detection engine profile. Default is Medium. MEDIUM is recommended for most systems because it offers a good balance between memory consumption and performance. LOW uses less memory, but it offers lower performance. HIGH consumes a large amount of memory, but it offers the highest performance.
Multi-Pattern Matcher Algorithm	Auto Choose a multi-pattern matcher (MPM) algorithm. Auto is the default, and is the best choice for almost all systems. Auto will use hyperscan if available.
Single-Pattern Matcher Algorithm	Auto Choose a single-pattern matcher (SPM) algorithm. Auto is the default, and is the best choice for almost all systems. Auto will use hyperscan if available.
Signature Group Header MPM Context	Auto Choose a Signature Group Header multi-pattern matcher context. Default is Auto. AUTO means Suricata selects between Full and Single based on the MPM algorithm chosen. FULL means every Signature Group has its own MPM context. SINGLE means all Signature Groups share a single MPM context. Using FULL can improve performance at the expense of significant memor consumption.
Inspection Recursion Limit	3000 Enter limit for recursive calls in content inspection code. Default is 3000. When set to 0 an internal default is used. When left blank there is no recursion limit.
Delayed Detect	☐ Suricata will build list of signatures after packet capture threads have started. Default is Not Checked.
Promiscuous Mode	☑ Suricata will place the monitored interface in promiscuous mode when checked. Default is Checked.
Interface PCAP Snaplen	1518 Enter value in bytes for the interface PCAP snaplen. Default is 1518. This parameter is only valid when IDS or Legacy Mode IPS is enabled. This value may need to be increased if the physical interface is passing VLAN traffic and expected alerts are not being received.

Networks Suricata Should Inspect and Protect

Home Net	default [View List] Choose the Home Net you want this interface to use. Default Home Net adds only local networks, WAN IPs, Gateways, VPNs and VIPs. Create an Alias to hold a list of friendly IPs that the firewall cannot see or to customize the default Home Net.
External Net	default [View List] Choose the External Net you want this interface to use. External Net is networks that are not Home Net. Most users should leave this setting at default. Create a Pass List and add an Alias to it, and then assign the Pass List here for custom External Net settings.

Alert Suppression and Filtering

Alert Suppression and Filtering	default [View List] Choose the suppression or filtering file you want this interface to use. Default option disables suppression and filtering.

Arguments here will be automatically inserted into the Suricata configuration

Advanced Configuration Pass-Through	Enter any additional configuration parameters to add to the Suricata configuration here, separated by a newline

CREACIÓN DE REGLAS

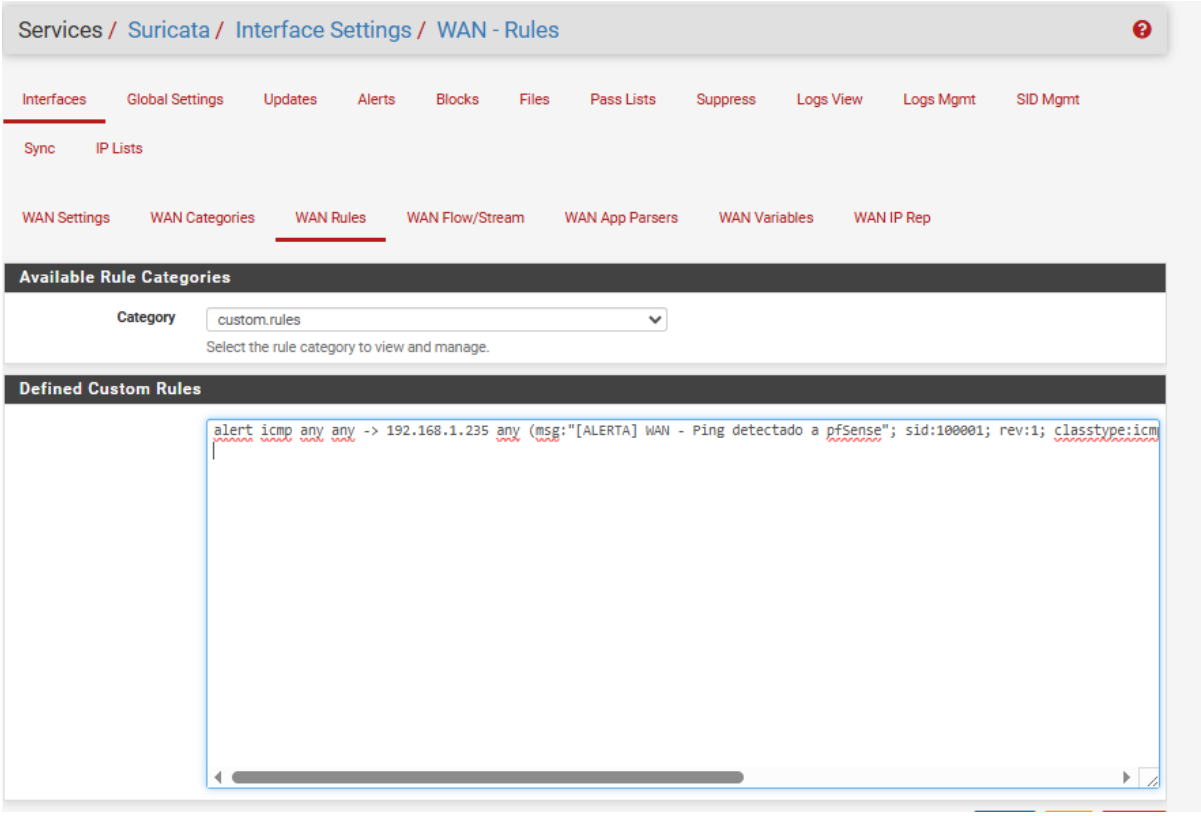
La **primera regla** a crear será el ping , para que detecte cuando se hace ping al servidor pfsense.

alert icmp any any -> 192.168.1.235 any (msg:"[ALERTA] WAN - Ping detectado a pfSense"; sid:100001; rev:1; classtype:icmp-event; itype:8; threshold: type limit, track by_src, count 1, seconds 10; priority:2;).

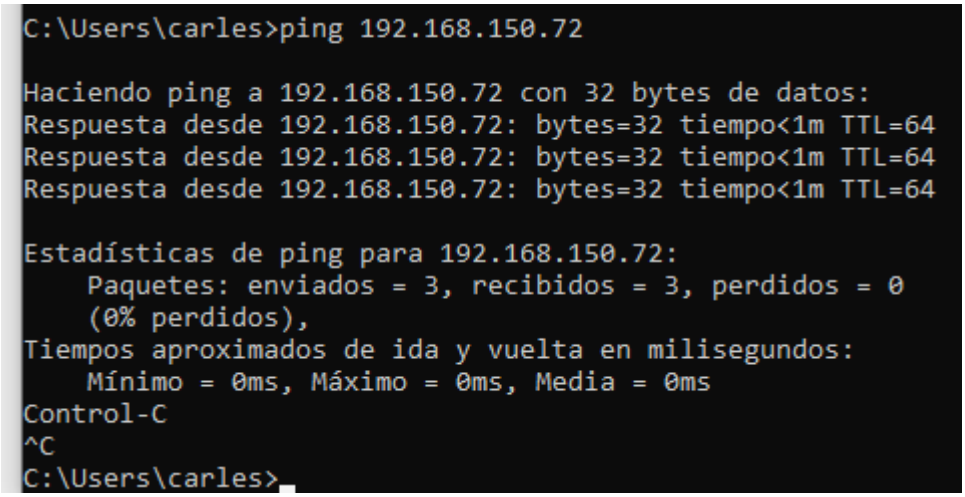
Type limit:
Solo se permite una alerta dentro del tiempo indicado. Es decir, limita la cantidad de veces que Suricata genera alertas.
track by_src:
Suricata vigila cada IP de origen que genera tráfico (en este caso, ICMP - ping).
count 1:
Suricata permitirá solo una alerta por IP de origen dentro del tiempo indicado.
seconds 10:
Ese "tiempo indicado" es de 10 segundos. Después de eso, vuelve a permitir una alerta si se repite el comportamiento.

Imagina que un dispositivo con IP 192.168.1.5 está haciendo muchos ping a pfSense.
Sin la regla threshold, Suricata generaría una alerta por cada paquete (muchísimas alertas en segundos).
Con esta regla, si 192.168.1.5 hace 100 pings en 10 segundos, solo se genera una alerta, y no otra hasta pasados 10 segundos.

La regla se debe introducir en

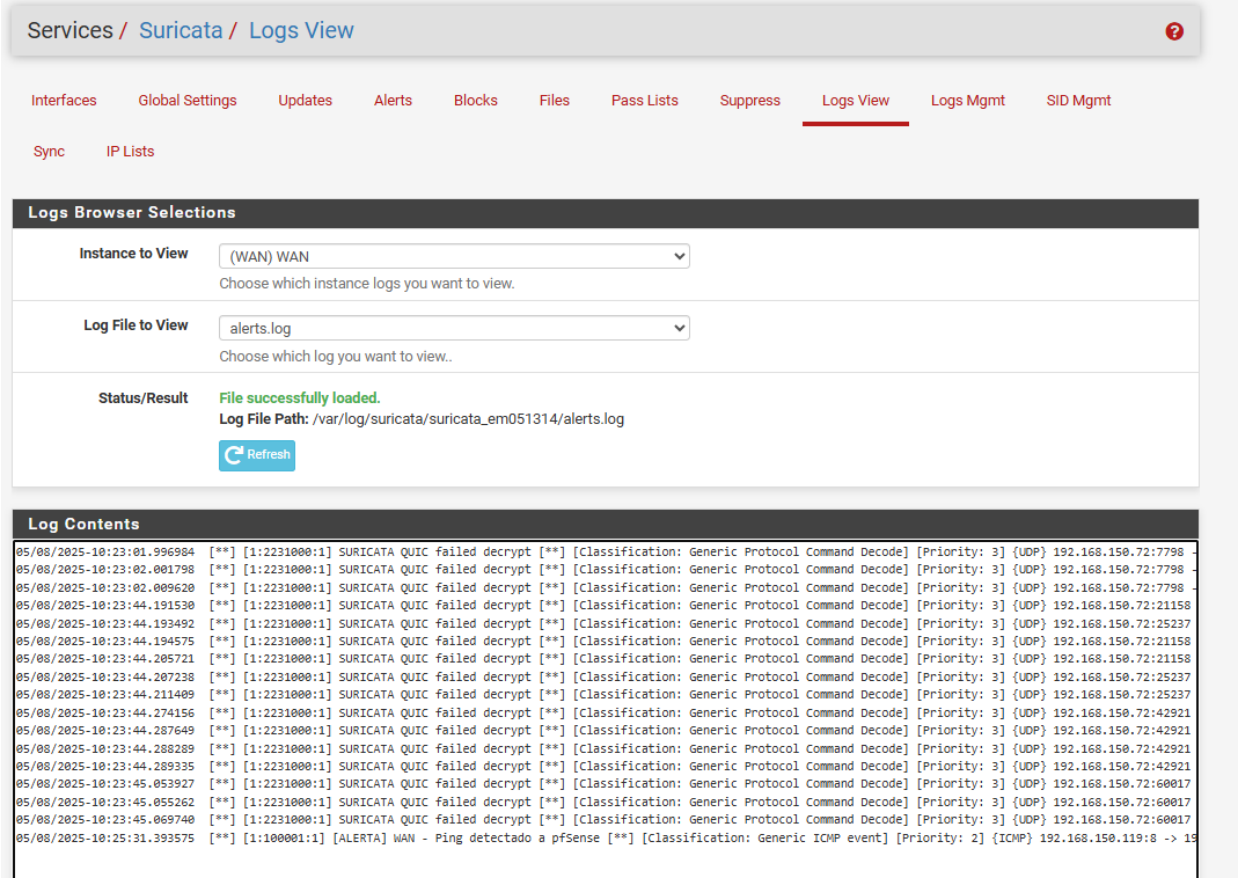


Y si hacemos un ping al servidor



```
C:\Users\carles>ping 192.168.150.72

Haciendo ping a 192.168.150.72 con 32 bytes de datos:
Respuesta desde 192.168.150.72: bytes=32 tiempo<1m TTL=64
Respuesta desde 192.168.150.72: bytes=32 tiempo<1m TTL=64
Respuesta desde 192.168.150.72: bytes=32 tiempo<1m TTL=64

Estadísticas de ping para 192.168.150.72:
    Paquetes: enviados = 3, recibidos = 3, perdidos = 0
    (0% perdidos),
Tiempos aproximados de ida y vuelta en milisegundos:
    Mínimo = 0ms, Máximo = 0ms, Media = 0ms
Control-C
^C
C:\Users\carles>
```

Aparecerá en el log que alguien esta realizando ping al servidor desde que dirección, etc.

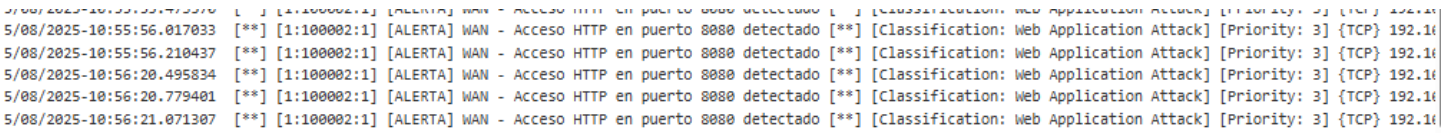


La **siguiente alerta** es para detectar si alguien accede a http://192.168.1.235:8080

- si cualquier IP y puerto (desde cualquier origen) intenta conectarse por TCP al puerto 8080 alert tcp any any -> 192.168.1.235 8080
- count 3 → Solo alerta una vez si se detectan 3 accesos en 10 segundos desde la misma IP.
- seconds 10 → Reinicia el conteo cada 10 segundos.
- track by_src → Agrupa por IP de origen (quién está haciendo la petición).

alert tcp any any -> 192.168.1.235 8080 (msg:"[ALERTA] WAN - Acceso HTTP en puerto 8080 detectado"; sid:100002; rev:1; classtype:web-application-attack; flow:to_server,established; content:"GET"; http_method; threshold: type limit, track by_src, count 3, seconds 10; priority:3;)

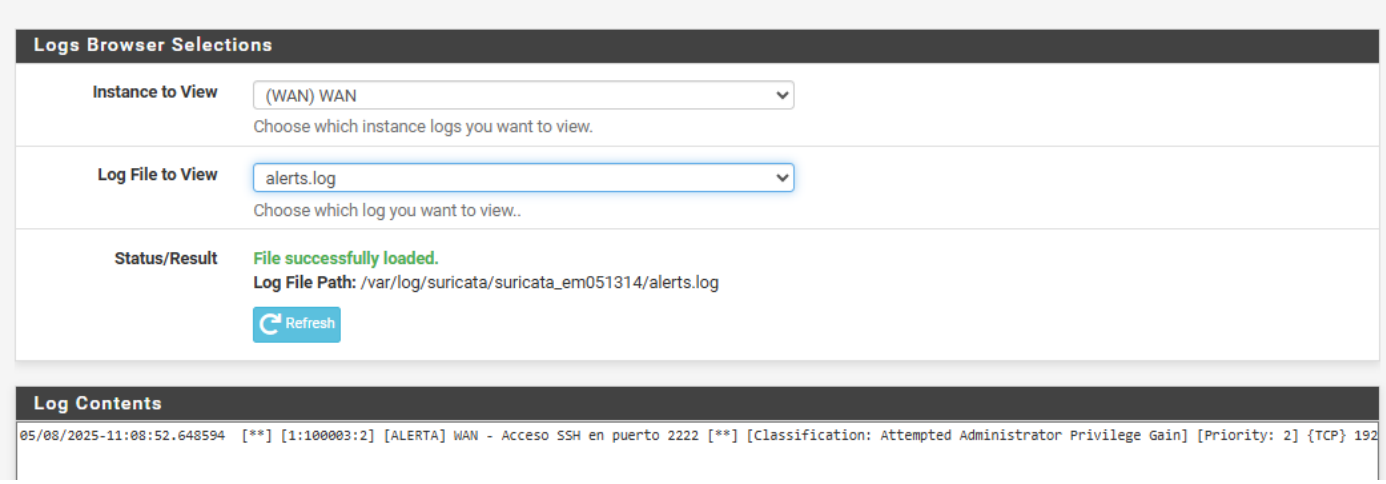
Ahora si accedo al puerto 192.168.150.72 una o dos o tres veces se me alertará pero si accedo 5 veces en menos de 10 segundos saldrán maximo 3



Siguiente alerta

alert tcp any any -> 192.168.1.235 2222 (msg:"[ALERTA] WAN - Acceso SSH en puerto 2222"; sid:100003; rev:2; classtype:attempted-admin; flow:to_server,established; content:"SSH-"; depth:4; threshold: type limit, track by_src, count 1, seconds 10; priority:2;)

```
carlesochoa@carles: ~
Microsoft Windows [Versión 10.0.19045.5737]
(c) Microsoft Corporation. Todos los derechos reservados.

C:\Users\carles>ssh carlesochoa@192.168.150.72 -p 2222
carlesochoa@192.168.150.72's password:
Welcome to Ubuntu 24.04.2 LTS (GNU/Linux 6.8.0-59-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

 System information as of jue 08 may 2025 11:08:55 UTC

  System load:  0.09              Processes:               105
  Usage of /:   45.1% of 9.75GB   Users logged in:         1
  Memory usage: 10%               IPv4 address for enp0s3: 192.168.20.2
  Swap usage:   0%


El mantenimiento de seguridad expandido para Applications está desactivado

Se pueden aplicar 63 actualizaciones de forma inmediata.
Para ver estas actualizaciones adicionales, ejecute: apt list --upgradable

Active ESM Apps para recibir futuras actualizaciones de seguridad adicionales.
Vea https://ubuntu.com/esm o ejecute «sudo pro status»


Last login: Mon May  5 08:07:33 2025 from 192.168.150.119
carlesochoa@carles:~$
```



Alerta para saber si alguien esta escaneando la red con nmap. Para si akguien realiza un nmap 192.168.1.72 para ver los puertos que se detecte.

alert tcp any any -> 192.168.150.72 any (msg:"[ALERTA] WAN - Escaneo de red con Nmap detectado"; sid:100005; rev:5; classtype:network-scan; flags:S; threshold: type both, track by_src, count 5, seconds 10; priority:2;).

IMPLEMENTACIÓN CON SNORT

¿Y qué tiene que ver Snort?

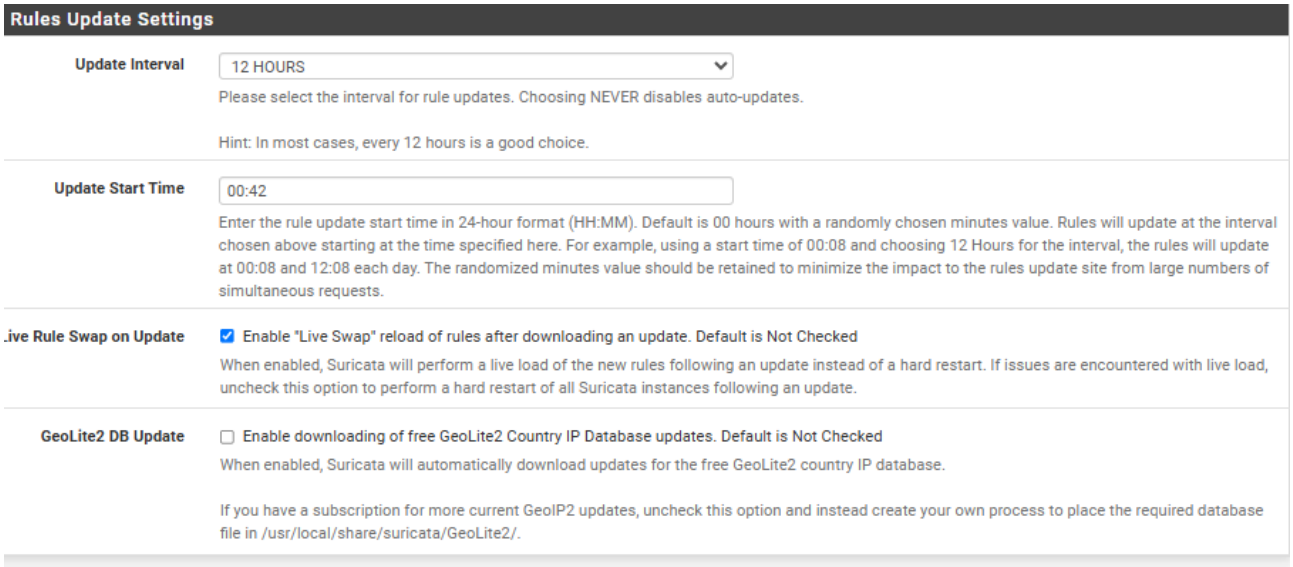
Snort es otro IDS, pero también es conocido por su formato de reglas.
Suricata es compatible con las reglas de Snort, así que puedes usar esas reglas en Suricata.

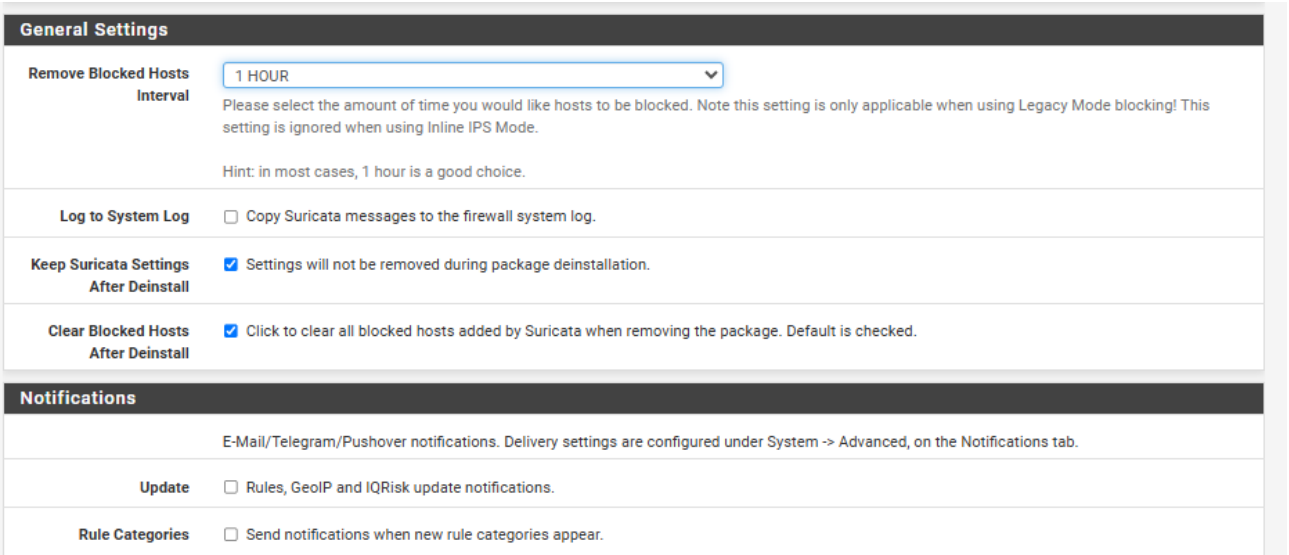
Que hay que hacer realmente?

Descargar un conjunto de reglas (como las de Snort o Emerging Threats).
Estas reglas le dicen a Suricata qué buscar (por ejemplo, ataques web, escaneos de puertos, malware...).

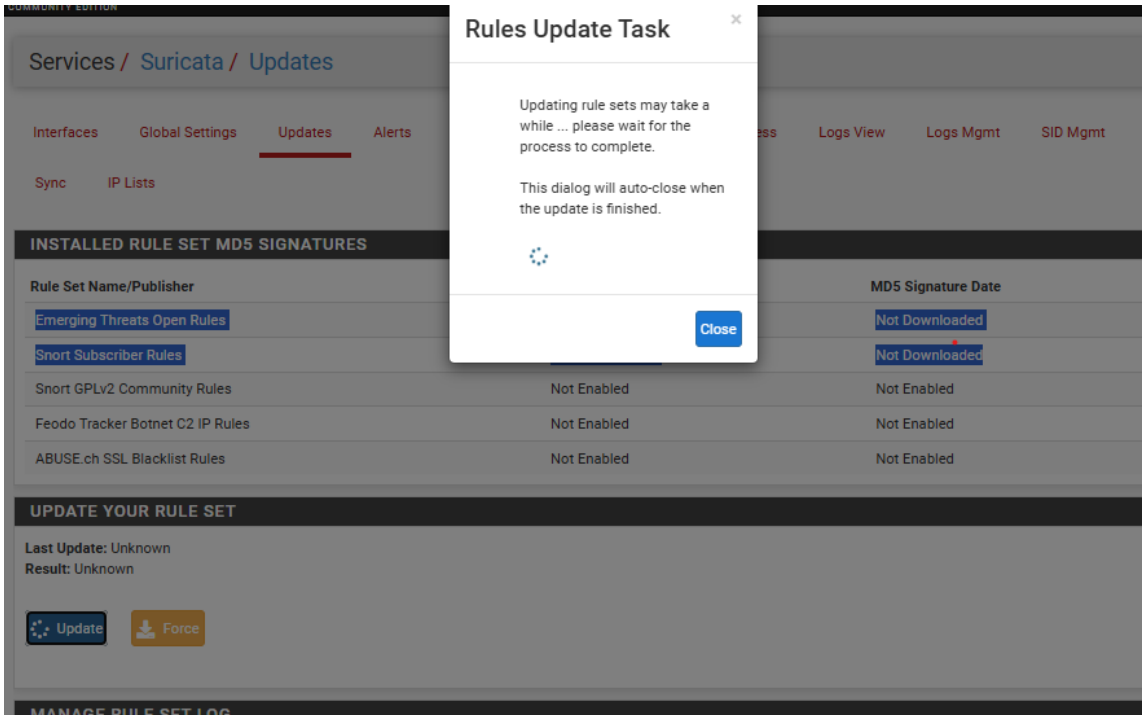
Please Choose The Type Of Rules You Wish To Download

Install ETOpen Emerging Threats rules	☑ ETOpen is a free open source set of Suricata rules whose coverage is more limited than ETPro. ☐ Use a custom URL for ETOpen downloads Enabling the custom URL option will force the use of a custom user-supplied URL when downloading ETOpen rules.
Install ETPro Emerging Threats rules	☐ ETPro for Suricata offers daily updates and extensive coverage of current malware threats. ☐ Use a custom URL for ETPro rule downloads The ETPro rules contain all of the ETOpen rules, so the ETOpen rules are not required and are disabled when the ETPro rules are selected. Sign Up for an ETPro Account. Enabling the custom URL option will force the use of a custom user-supplied URL when downloading ETPro rules.
Install Snort rules	☑ Snort free Registered User or paid Subscriber rules ☐ Use a custom URL for Snort rule downloads Sign Up for a free Registered User Rules Account Sign Up for paid Snort Subscriber Rule Set (by Talos) Enabling the custom URL option will force the use of a custom user-supplied URL when downloading Snort Subscriber rules.
Snort Rules Filename	snortrules-snapshot-29200.tar.gz Enter the rules tarball filename (filename only, do not include the URL.) Example: snortrules-snapshot-29200.tar.gz DO NOT specify a Snort3 rules file! Snort3 rules are incompatible with Suricata and will break your installation!
Snort Oinkmaster Code	970e41b17d0e94ecd30eaa480c21d530e19f1166 Obtain a snort.org Oinkmaster code and paste it here.
Install Snort GPLv2 Community rules	☐ The Snort Community Ruleset is a GPLv2 Talos-certified ruleset that is distributed free of charge without any Snort Subscriber License restrictions. ☐ Use a custom URL for Snort GPLv2 rule downloads This ruleset is updated daily and is a subset of the subscriber ruleset. If you are a Snort Subscriber Rules customer (paid subscriber), the community ruleset is already built into your download of the Snort Subscriber rules, and there is no benefit in adding this rule set separately.
Install Feodo Tracker Botnet C2 IP rules	☐ The Feodo Botnet C2 IP Ruleset contains Dridex and Emotet/Heodo botnet command and control servers (C&Cs) tracked by Feodo Tracker.
Install ABUSE.ch SSL Blacklist rules	☐ The ABUSE.ch SSL Blacklist Ruleset contains the SSL cert fingerprints of all SSL certs blacklisted by ABUSE.ch.
Hide Deprecated Rules Categories	☐ Hide deprecated rules categories in the GUI and remove them from the configuration. Default is Not Checked.
Download Extra Rules	☐ Download Extra Rules Download extra rules file or tar.gz archive with rules. If "Check MD5" is set, the code will assume a matching filename exists at the same URL with an additional extension of ".md5".





Actualizamos las reglas

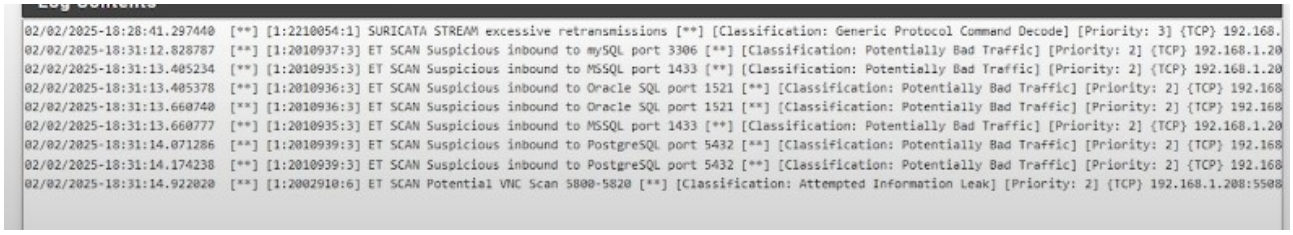


Y con esto lo que se ha realizado es obtener muchas mas reglas (ServicesSuricataInterface SettingsWAN – Categories).

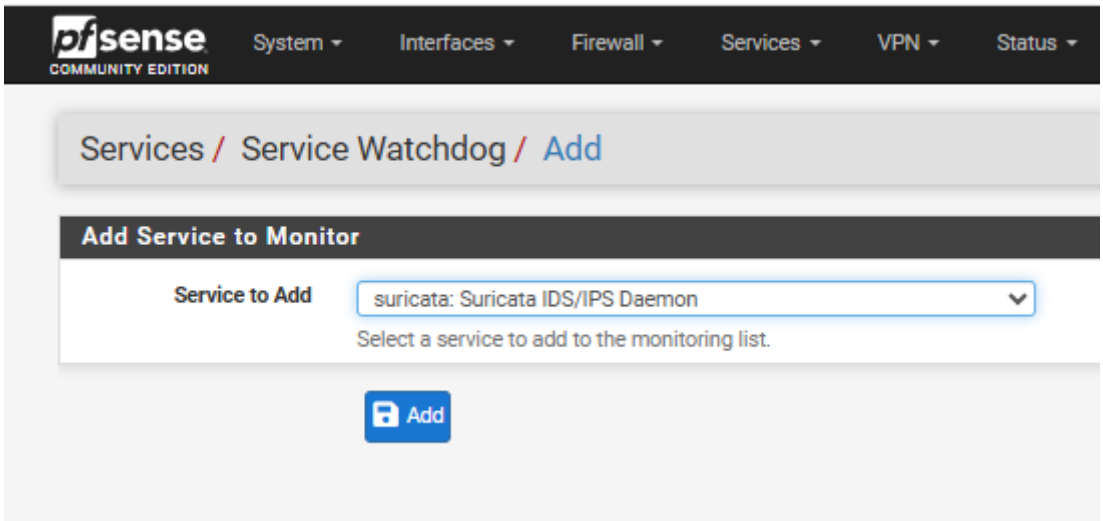
Que las seleccionaremos todas para que se apliquen. Aplicando estas reglas tendremos muchas m´s reglas en funcionamiento para que detecten todo tipo de tráfico en la red.

Enabled			Ruleset:		
Enabled	Ruleset: Default Rules	Enabled	Ruleset: ET Open Rules	Enabled	Ruleset: Snort Text Rules
☑	app-layer-events.rules	☐	emerging-activex.rules	☐	snort_app-detect.rules
☑	decoder-events.rules	☐	emerging-adware_pup.rules	☐	snort_attack-responses.rules
☑	dhcp-events.rules	☐	emerging-attack_response.rules	☐	snort_backdoor.rules
☑	dnp3-events.rules	☐	emerging-botcc.portgrouped.rules	☐	snort_bad-traffic.rules
☑	dns-events.rules	☐	emerging-botcc.rules	☐	snort_blacklist.rules
☑	files.rules	☐	emerging-chat.rules	☐	snort_botnet-cnc.rules
☑	ftp-events.rules	☐	emerging-ciarmy.rules	☐	snort_browser-chrome.rules
☑	http-events.rules	☐	emerging-coinminer.rules	☐	snort_browser-firefox.rules
☑	http2-events.rules	☐	emerging-compromised.rules	☐	snort_browser-ie.rules
☑	ipsec-events.rules	☐	emerging-current_events.rules	☐	snort_browser-other.rules
☑	kerberos-events.rules	☐	emerging-deleted.rules	☐	snort_browser-plugins.rules
☑	modbus-events.rules	☐	emerging-dns.rules	☐	snort_browser-webkit.rules
☑	mqtt-events.rules	☐	emerging-dos.rules	☐	snort_chat.rules
☑	nfs-events.rules	☐	emerging-drop.rules	☐	snort_content-replace.rules
☑	ntp-events.rules	☐	emerging-dshield.rules	☐	snort_ddos.rules
☑	quic-events.rules	☐	emerging-dyn_dns.rules	☐	snort_deleted.rules
☑	rfb-events.rules	☐	emerging-exploit.rules	☐	snort_dns.rules
☑	smb-events.rules	☐	emerging-exploit_kit.rules	☐	snort_dos.rules
☑	smtp-events.rules	☐	emerging-file_sharing.rules	☐	snort_experimental.rules
☑	ssh-events.rules	☐	emerging-ftp.rules	☐	snort_exploit-kit.rules
☑	stream-events.rules	☐	emerging-games.rules	☐	snort_exploit.rules
☑	tls-events.rules	☐	emerging-hunting.rules	☐	snort_file-executable.rules
		☐	emerging-icmp.rules	☐	snort_file-flash.rules
		☐	emerging-imap.rules	☐	snort_file-identify.rules
		☐	emerging-inappropriate.rules	☐	snort_file-image.rules
		☐	emerging-info.rules	☐	snort_file-java.rules
		☐	emerging-ja3.rules	☐	snort_file-multimedia.rules
		☐	emerging-malware.rules	☐	snort_file-office.rules
		☐	emerging-misc.rules	☐	snort_file-other.rules
		☐	emerging-mobile_malware.rules	☐	snort_file-pdf.rules
		☐	emerging-pathing.rules	☐	snort_finger.rules

Por ejemplo si alguien hace un escaneo de una ip con nmap ahora aparecerán todas estas reglas en cuanto antes solo con la que predefinimos anteriormente solo era de que si alguien hace el escaneo que solo aparezca UNA SOLA regla.



```
02/02/2025-18:28:41.297440  [**] [1:2210054:1] SURICATA STREAM excessive retransmissions [**] [Classification: Generic Protocol Command Decode] [Priority: 3] {TCP} 192.168.
02/02/2025-18:31:12.828787  [**] [1:2010937:3] ET SCAN Suspicious inbound to mySQL port 3306 [**] [Classification: Potentially Bad Traffic] [Priority: 2] {TCP} 192.168.1.20
02/02/2025-18:31:13.405234  [**] [1:2010935:3] ET SCAN Suspicious inbound to MSSQL port 1433 [**] [Classification: Potentially Bad Traffic] [Priority: 2] {TCP} 192.168.1.20
02/02/2025-18:31:13.405378  [**] [1:2010936:3] ET SCAN Suspicious inbound to Oracle SQL port 1521 [**] [Classification: Potentially Bad Traffic] [Priority: 2] {TCP} 192.168
02/02/2025-18:31:13.660740  [**] [1:2010936:3] ET SCAN Suspicious inbound to Oracle SQL port 1521 [**] [Classification: Potentially Bad Traffic] [Priority: 2] {TCP} 192.168
02/02/2025-18:31:13.660777  [**] [1:2010935:3] ET SCAN Suspicious inbound to MSSQL port 1433 [**] [Classification: Potentially Bad Traffic] [Priority: 2] {TCP} 192.168.1.20
02/02/2025-18:31:14.071286  [**] [1:2010939:3] ET SCAN Suspicious inbound to PostgreSQL port 5432 [**] [Classification: Potentially Bad Traffic] [Priority: 2] {TCP} 192.168
02/02/2025-18:31:14.174238  [**] [1:2010939:3] ET SCAN Suspicious inbound to PostgreSQL port 5432 [**] [Classification: Potentially Bad Traffic] [Priority: 2] {TCP} 192.168
02/02/2025-18:31:14.922020  [**] [1:2002910:6] ET SCAN Potential VNC Scan 5800-5820 [**] [Classification: Attempted Information Leak] [Priority: 2] {TCP} 192.168.1.208:5508
```

Por último instalaremos el **paquete watchdog** eso lo que hará es que si un servicio de OpenVPN, Squid (proxy) o Suricata deja de funcionar por un fallo, Watchdog lo detecta y lo vuelve a iniciar automáticamente. Esto garantiza la continuidad del servicio sin intervención manual.

Primero habrá que instalar el paquete y luego ir a services»Service Watchdog y añadir a suricata y todos los servicios que se deseen.